

Cindy Alejandra Pineda García

ACTIVIDAD 01 Análisis y planificación del pentest

1. Objetivo del pentest

- Identificar si existen fallas de control de acceso entre cuentas de usuario (como la reportada por el cliente) que permitan a una persona ver o modificar información que no le pertenece.
- Evaluar la robustez de los mecanismos de autenticación y gestión de sesiones de la aplicación web, para determinar si es posible suplantar, secuestrar o acceder a una sesión ajena, o escalar de un rol de cliente a uno administrativo.
- Entregar a Aurora Market un informe claro y priorizado por nivel de riesgo, con recomendaciones concretas de remediación, que le permita tomar decisiones informadas para proteger la información de sus clientes y fortalecer la seguridad de la plataforma a futuro.

2. Alcance

SÍ SE EVALUARÁ

- La aplicación web de Aurora Market en su totalidad: registro, inicio de sesión, catálogo y búsqueda de productos, carrito de compras, proceso de compra e historial/estado de pedidos.
- El área administrativa donde el personal de Aurora Market gestiona productos, usuarios y pedidos, incluyendo la separación de privilegios entre clientes y personal interno.
- Los mecanismos de autenticación, manejo de sesiones y controles de autorización entre distintos usuarios y roles.
- Las APIs o servicios internos que la aplicación web consuma directamente para su funcionamiento, en la medida en que formen parte de la infraestructura autorizada.

FUERA DEL ALCANCE

- Las redes sociales oficiales de Aurora Market.
- Los equipos personales y cuentas de correo de los empleados.
- Proveedores externos y sistemas de terceros que no formen parte directa de la aplicación web autorizada.
- Cualquier sistema, entorno o activo no incluido explícitamente en el documento de autorización.

3. Autorización y condiciones

PERMISOS REQUERIDOS

- Autorización formal por escrito, firmada por un representante de Aurora Market, que respalde legalmente la ejecución del pentest.
- Documento de alcance con las URLs, entornos y funcionalidades autorizadas para las pruebas.
- Un punto de contacto técnico y uno de negocio dentro de Aurora Market para coordinar el trabajo y escalar hallazgos urgentes.
- Acceso a cuentas de prueba en los distintos roles definidos (cliente y personal administrativo), cuando sea posible, para no usar datos reales.

CONDICIONES ACORDADAS

- No interrumpir deliberadamente el funcionamiento de la plataforma ni ejecutar pruebas de denegación de servicio.
- No exponer, modificar ni exfiltrar información real de los clientes; documentar la evidencia sin extraer datos innecesarios.

- Ejecutar las pruebas dentro de los horarios de menor actividad acordados con Aurora Market.
- Mantener confidencialidad sobre los hallazgos hasta la entrega formal del informe, y reportar de inmediato cualquier vulnerabilidad crítica.

4. Tipo de pentest

- **Tipo de pentest elegido:** Gray-box (caja gris)



Justificación de la elección: Aurora Market entregó al equipo información parcial, sabe que existe una aplicación web, una base de datos, mecanismos de autenticación y distintos tipos de usuario, pero no compartió el código fuente ni todos los detalles de la infraestructura o las tecnologías utilizadas. Ese nivel de conocimiento parcial corresponde a un pentest de caja gris: permite simular tanto el punto de vista de un atacante externo como el de un usuario ya registrado (similar al que reportó el incidente)

5. Planificación

- **Objetivos:** Los tres objetivos definidos en el punto 1: validar el control de acceso entre cuentas, evaluar autenticación/sesiones y entregar un informe accionable.
- **Alcance:** La aplicación web de Aurora Market y su panel administrativo, según lo definido en el punto 2.
- **Permisos y condiciones:** Autorización formal firmada y las condiciones acordadas con Aurora Market descritas en el punto 3.
- **Metodología a utilizar:** OWASP Testing Guide (OWASP WSTG), apoyada en el marco general del PTES para organizar las fases del trabajo.
- **Recopilación de información previa:** Mapear de forma pasiva las funcionalidades públicas de la aplicación, los roles de usuario existentes, los flujos donde se maneja información sensible (registro, pedidos, perfil) y las tecnologías visibles, sin interactuar de forma intrusiva.
- **Recursos necesarios:** Cuentas de prueba en los distintos roles, un entorno o ventana de pruebas acordada, herramientas como Burp Suite/OWASP ZAP para interceptar tráfico y Nmap para reconocimiento, y el tiempo del equipo asignado al proyecto.
- **Programación del pentest:** Ejecutar las pruebas en los horarios de menor actividad definidos por Aurora Market, con fechas de inicio, duración estimada y fecha de entrega del informe acordadas previamente con la empresa.

6. Fases del pentest

- **1. Reconocimiento:** Identificar dominios y subdominios de Aurora Market, tecnologías visibles, endpoints públicos y el flujo funcional completo de la aplicación (registro, login, carrito, pedidos), sin realizar acciones intrusivas.
- **2. Análisis de vulnerabilidades:** Revisar cada funcionalidad en busca de fallas comunes: control de acceso roto entre cuentas (IDOR), debilidades de autenticación o de manejo de sesión, y exposición de información sensible, con especial atención al área relacionada con el incidente reportado por el cliente.
- **3. Explotación:** Confirmar de forma controlada, en un entorno o con cuentas de prueba, si es posible acceder a información de otra cuenta (por ejemplo alterando identificadores de usuario o de pedido), evitando en todo momento afectar datos reales de clientes.
- **4. Post-explotación:** Determinar el impacto real de cada hallazgo confirmado: qué tipo de información podría exponerse, si existe posibilidad de escalar desde una cuenta de cliente hacia el panel administrativo, y qué tan grave sería ese riesgo para el negocio.
- **5. Informe:** Documentar cada hallazgo con evidencia, nivel de riesgo, impacto para Aurora Market y recomendaciones de remediación priorizadas, en un lenguaje claro que el equipo de desarrollo pueda entender y aplicar.

7. Investigación

- **Metodología elegida:** OWASP Testing Guide (OWASP WSTG)

¿Por qué sería útil para este proyecto?: El OWASP WSTG es una metodología orientada específicamente a la evaluación de aplicaciones web como la de Aurora Market. Incluye módulos detallados para probar la gestión de sesiones, la autenticación y, sobre todo, el control de acceso — justo el área relacionada con el incidente que motivó esta evaluación—, además de ser un estándar ampliamente reconocido que facilita estructurar tanto las pruebas técnicas como el informe final de forma clara y profesional.